

Week 3 — Tuesday Lab: Login, Sessions & Auth Functions

IM102 – Advanced Database Systems | 3 Hours | Computer Lab

Concept: Sessions

HTTP is stateless — every page request is independent. The server forgets you between pages. Sessions fix this.

```
session_start();           // Start/resume a session
$_SESSION['user_id'] = 5;   // Store something
$_SESSION['username'] = 'juan';

// On ANY other page (after session_start()):
echo $_SESSION['username']; // 'juan' — it remembered!
```

Behind the scenes: PHP sends a cookie to the browser with a session ID. The browser sends it back on every request. PHP uses that ID to load your saved data.

Example: auth.php

Create one file with reusable auth functions instead of copying the same checks everywhere:

```
<?php
session_start();

function requireLogin() {
    if (!isset($_SESSION['user_id'])) {
        header('Location: login.php');
        exit;
    }
}

function isLoggedIn() {
    return isset($_SESSION['user_id']);
}

function isAdmin() {
    return isset($_SESSION['role']) && $_SESSION['role'] === 'admin';
}
```

Example: Login Handler

```
// Find the user
$result = $conn->query("SELECT * FROM users WHERE username = '$username'");
$user = $result->fetch_assoc();
```

```
// Verify password against stored hash
if ($user && password_verify($password, $user['password_hash'])) {
    $_SESSION['user_id'] = $user['id'];
    $_SESSION['username'] = $user['username'];
    $_SESSION['role'] = $user['role'];
    header('Location: index.php');
    exit;
}
```

Notice: if the user doesn't exist OR the password is wrong, show the same error message. Don't reveal which part failed.

Your Turn

Create `auth.php` with: `requireLogin()`, `isLoggedIn()`, `isAdmin()`, `requireAdmin()` (dies with "Access denied" if not admin), and `getUsername()`. Add `session_start()` at the top.

Build `login.php` — form with username and password, find the user, verify with `password_verify()`, set session variables, redirect on success. If already logged in, redirect away from the login page.

Build `logout.php` — destroy the session and redirect to login.

Add `requireLogin()` to the top of `index.php` and `report.php`. Now those pages are protected — you can't see them without logging in.